

DIB: Managing Local MUD Policy Lifecycles with Shared IoT Traffic Evidence

Anonymous Authors

Abstract—Shared IoT traffic observations can support Manufacturer Usage Description (MUD) policy drafting across independent administrative domains, but provide evidence, not local authority. Device Intent Blueprint (DIB) separates shared evidence from per-site authorization through explicit approval, dispute, revocation, and restoration semantics. Only local operators authorize export; disputes invalidate authorization, and restoration requires renewed approval while preserving local revocations. A finite TLA+ model checks these properties across 3,837,084 reachable states; mutation controls expose restoration and site-confinement failures, and registry regression testing identified and corrected a revocation-handling mismatch. An OpenWrt/osMUD testbed validates policy application on a reachable gateway. A single-host, ten-site distributed deployment reconciles disconnected sites in 0.51 s; an extended finite model checks safety only among reachable, reconciled sites. A matched cold-start comparison across three deployments and six device types reduces candidate counts by 92.3–96.4% relative to pooled observations, cutting review cost from 4.3–28.3 to 1.03–2.89 inspected candidates per confirmed endpoint while lowering recall. Quorum drives most of the reduction; additional filters have receiver-dependent costs. A separate reference-profile evaluation retains 63.2% of observable macro behavior with 7.9% complete-profile recall. DIB manages partial policy proposals under authenticated-consortium assumptions; it neither establishes benignity nor guarantees immediate withdrawal at unreachable gateways.

Index Terms—IoT security, Manufacturer Usage Description, distributed network management, access policy management, policy lifecycle.

I. INTRODUCTION

Manufacturer Usage Description (MUD) [2] lets an Internet-of-Things (IoT) device advertise its intended communications, which a MUD manager translates into access-control rules. Manufacturer profiles may be unavailable or become stale as firmware and cloud services change [9], [29]; traffic observations can help draft or update them.

Sharing observations across administrative domains can seed proposals before sufficient local traffic is collected. An endpoint needed in one network may be unnecessary elsewhere, and compromised devices may contact attacker-controlled destinations [1], [29]. Remote observations therefore supply evidence, not authority: cross-network agreement can prioritize review, while only the receiving site’s operator can authorize activation.

Consider a camera without a manufacturer profile: two peer networks report a service, which the local administrator approves. A peer later disputes it. The management system must invalidate approval, propagate withdrawal to the gateway, and resolve the dispute without reusing old permissions or overriding local revocations. An approval prompt alone specifies neither this lifecycle nor reconciliation after disconnection.

We present *Device Intent Blueprint (DIB)*, a policy-management framework for independently administered networks, or *sites*. A shared *registry* separates evidence from per-site authorization records. An *endpoint fact* identifies a communication by device type, direction, protocol, peer, and port. Eligible facts enter review as *MONITORONLY*, producing no MUD entry or firewall rule. A local approval, or *commit*, makes the record *ACTIVE*, authorizing MUD export. Gateway fetch and application are separate: registry withdrawal does not immediately remove a rule at an unreachable gateway.

DIB tracks approval validity and revocation origin so restoration after shared withdrawal requires fresh approval without erasing local vetoes. This lifecycle, rather than traffic classification, is the management contribution; candidate filtering controls proposal volume without establishing benignity.

The paper makes three contributions:

- **Lifecycle semantics.** We separate shared evidence from local authority and define approval, dispute, revocation, restoration, and export transitions. A finite TLA+ model checks authorization safety and preservation of local vetoes over 3,837,084 reachable states.
- **Execution and reconciliation.** A registry and OpenWrt/osMUD testbed connect lifecycle decisions to MUD export and firewall updates. A ten-site distributed deployment tests reconciliation after missed dispute/restore events; an extended finite model checks safety among reachable, reconciled sites.
- **Proposal-volume trade-offs.** UNSW-IoTraffic [4], Mon(IoT)r [26], and YourThings [27] experiments quantify candidate reduction, coverage loss, and cold-start transfer. Matched ablations isolate quorum and filter effects; adversarial tests distinguish conditional rejection from empirical mitigation.

II. RELATED WORK

RFC 8520 leaves MUD profile authoring and management to administrators [2]. Prior work extracts or enforces profiles from local traffic within one administrative domain [3], [5]–[8], [14], rather than governing shared observations across domains.

Threat-intelligence sharing (MISP, STIX), contributor reputation [15]–[18], and collaborative IoT learning (CoLearn, DIoT, IoT Inspector) [11]–[13], [28] provide related mechanisms for aggregating evidence, traffic models, or anomaly reports. Evidence quality alone does not authorize network reachability.

TABLE I
DEFINED WORKFLOW ALTERNATIVES FOR ONE FACT, INITIALLY
APPROVED AT SITE s . THE SEQUENCE IS LOCAL REVOKE AT s , PEER
DISPUTE, THEN GLOBAL RESTORE.

Workflow	Global-restore rule	Result at s
Approval + persistent approval bit	Reuse old approval	Permission can return without fresh approval
Approval + review reset	Reset all revoked records to review	No permission, but local veto is erased
Provenance-aware review (DIB)	Reset only dispute-derived records	Local revocation survives; no permission

Cross-domain policy frameworks address distributed authoring, provenance, or consistency [10], [19]–[25], [31]–[34]. DIB focuses on how shared disputes and restoration interact with independent local decisions. No published system combines MUD policy objects, evidence contributed across administrative domains, and a per-site authorization record with dispute-driven withdrawal and restoration. MUD work operates inside one domain [3], [5]–[8], [14]; cross-domain access-control frameworks operate on identity and policy objects carrying no notion of contributed traffic evidence [32]–[34]; evidence-sharing platforms distribute indicators without a local authorization record to invalidate [11], [13], [15], [16]; and blockchain-backed MUD distribution [25] makes profiles tamper-evident without separating shared evidence from site-local authority. The available reference points are therefore the two ends of the design space DIB sits between: pooled union, which stages every shared observation, and reputation-weighted voting, which weights contributors but still yields one shared verdict. We evaluate against both (Sec. V). Table I accordingly compares defined workflow semantics: the alternatives are the restoration rules a system can implement, not deficiencies of any particular prior system. DIB contributes their composition for shared MUD proposals, finite-state verification, and executable withdrawal and re-approval.

III. THREAT MODEL AND GOALS

We consider a closed consortium of sites controlling their own gateways. Remote reports are distinct from local authorization.

A. Setting and Trust Boundary

The deployment is assumed to authenticate consortium membership out-of-band (e.g., mutual TLS with enterprise PKI), reject unauthenticated contributions, encrypt and authenticate registry communication, and enforce identities and roles. Device-taxonomy alignment is assumed complete before ingestion. Admission additionally assumes malicious contributors control at most fraction f_s of the eligible reporting population for a device type (Sec. IV-C); identity-inflation tests deliberately exceed this bound.

We evaluate three distinct adversarial behaviors: (i) **A1 (Poisoned Observations)**, where an honest site captures and reports real malicious flows from an already compromised device; (ii) **A2 (Fabricated Evidence)**, where contributors report fabricated traffic that did not occur (bounded by breadth share f_s , or unbounded in Sybil stress tests); and (iii) **A3**

(Low-and-Slow Behavioral Drift), where attacker activity is distributed across sites to mimic a legitimate rollout.

Local operators are sovereign within their domain: misuse of a local commit or revocation is an insider threat, not a cross-site authorization failure. Attackers may pollute review queues or disrupt availability through baseless disputes, but disputes are restrictive and cannot create ACTIVE authorization. A3 exposes an observational limit: identical traffic patterns yield identical scores regardless of benignity or intent [1], [29]. Without a local commit, admitted patterns remain unprivileged MONITORONLY candidates. Authorization tokens belong to the receiving site’s local state and cannot be created by remote contributors.

Consortium authority. A participating site can raise a dispute; the first dispute suspends export and a second distinct site confirms revocation. Global restoration is a privileged consortium operation whose authorization must be supplied by the deployment, and local approval, revoke, and restore must be bound to the receiving site’s operator: local control means exclusive creation of permissions, while consortium members accept shared emergency withdrawal. This deliberately favors restriction over availability, as a malicious member can interrupt service.

Scope of the safety properties. I1–I3 (Sec. IV-B) concern lifecycle transitions under authenticated identities. The prototype and finite model expose transitions to a trusted harness; correct caller authentication and role enforcement are deployment assumptions, not implemented or verified mechanisms.

B. Design Goals

We formulate five core design goals:

- **G1 (Local Authorization Sovereignty):** Export only locally approved endpoint facts representable as valid MUD access-control entries (ACEs).
- **G2 (Zero-Profile Bootstrapping):** Propose review candidates for newly observed devices even when manufacturer profiles are absent.
- **G3 (Candidate-Volume Reduction):** Reduce the number of proposals presented for review relative to pooling all observations.
- **G4 (Non-Destructive Rescoring):** Allow evolving evidence to update candidate scores without silently altering existing local approvals.
- **G5 (Adversarial Rejection):** Reject facts supported only by malicious contributors when their population share and the score parameters satisfy the bound in Section IV-C.

G1 and G4 protect authorization; G2, G3, and G5 concern candidate quality. Gateways determine effective enforcement.

IV. DEVICE INTENT BLUEPRINT

DIB separates candidate admission, site-local export authorization, and gateway application.

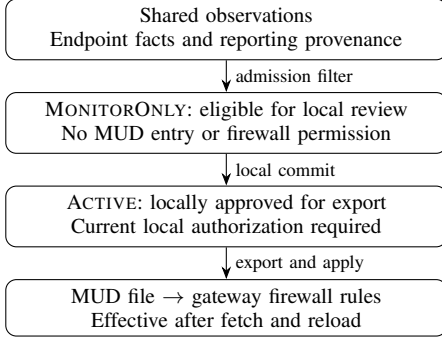


Fig. 1. Separate evidence, authorization, and enforcement steps. Admission creates proposals; local commit authorizes export; gateway application changes connectivity. Withdrawal invalidates authorization; restoration requires renewed approval.

A. Records and Operational Flow

For device type d , an endpoint fact is $f = (d, e)$, where $e = (\text{direction}, \text{protocol}, \text{peer}, \text{port})$. The peer is an FQDN or remote IP address; normalization prefers an observed FQDN when available. Scoring uses outbound tuples since the evaluated traffic predominantly concerns device-initiated communications; the exporter can also generate return-flow ACEs.

The registry keeps two kinds of record. *Shared evidence records* store observations, reporters, timestamps, and attestations as audit provenance: CONTRIBUTE records traffic idempotently, ATTEST records a site’s explicit stance on an admitted fact, and reporter counts give audit tiers (Local, Corroborated, Consortium-attested) that help review but grant no permission. *Site-local authority records* store each receiving site’s decision, approval validity, and revision history independently of the evidence.

Following the camera proposal. In Sec. I’s example, eligibility, reporter count, persistence, and dispute checks (Sec. IV-C) produce a MONITORONLY proposal, not a packet-monitoring rule. Local approval creates fresh authorization in ACTIVE; the serializer emits a MUD ACE for the gateway to fetch and apply.

A dispute invalidates authorization at all sites; gateways must apply the regenerated policy to withdraw installed permissions. A second independent dispute confirms revocation. Restoration returns applicable records to review without erasing local revocations (Table II); Fig. 1 shows the forward path.

B. Site-Local Authority Lifecycle

At each site s , an endpoint fact f resides in one of five authorization states:

$$S = \{\text{Absent}, \text{MonitorOnly}, \text{Active}, \text{Disputed}, \text{Revoked}\}.$$

These states track administrative authorization, distinct from gateway enforcement. ACTIVE indicates that site s ’s operator has authorized fact f for policy export. Each approval creates a fresh local authorization instance. The Boolean $\text{grantValid}[s][f]$ records whether that instance remains

valid; here, “token” denotes authorization state, not a bearer credential. A fact is exportable if and only if:

$$\text{Exportable}(s, f) \iff \text{state}(s, f) = \text{ACTIVE} \wedge \text{grantValid}(s, f). \quad (1)$$

Let Σ be the lifecycle events, including queries, commits, disputes, and restorations. We write $\delta : S \times \Sigma \rightarrow S$ for the state projection of the record transition; guards also depend on authorization validity, dispute status, and revocation origin (Table II). Absent means not staged; Disputed means suspended; Revoked retains whether withdrawal was local or dispute-derived.

Local revoke is defined only from Active or MONITORONLY, not from Disputed or Revoked (Dispute). Thus an operator cannot add an independent veto during suspension or after dispute-confirmed revocation. This matters because global restore returns dispute-derived records to review but must preserve local vetoes (I3). Local revoke becomes available again in MONITORONLY; local restore cannot release Revoked (Dispute). Extending veto recording to these states and re-verifying the lifecycle remain future work.

Core Invariants (I1–I3). Under the stated identity assumptions, the lifecycle requires:

- **(I1) Fresh Local Authorization:** Only an explicit OPERATOR-COMMIT by site s ’s operator can transition a fact to ACTIVE and generate a valid authorization token. No sequence σ of non-commit events (i.e., $\sigma \in \Sigma_{\text{non-commit}}^*$, any sequence drawn from events other than operator-commit) can enter ACTIVE, where $\hat{\delta}$ extends δ to sequences:

$$\forall s, f : \hat{\delta}(\text{Absent}, \sigma) \neq \text{Active}, \quad \forall \sigma \in \Sigma_{\text{non-commit}}^*.$$

- **(I2) Site Confinement:** Local actions (OPERATOR-COMMIT, LOCAL-REVOKE, LOCAL-RESTORE) at site s have no side effects on any peer site $s' \neq s$.
- **(I3) Conservative Reversal:** A dispute immediately clears export eligibility and invalidates authorization tokens across all sites. Restoration conservatively returns records to MONITORONLY without regenerating tokens, requiring fresh local re-authorization. Global restoration never overrides an independent local revocation.

Registry safety and gateway application. Let $\text{Exported}(s, f, t)$ denote an export event at time t . We call $\text{CurrentLocalAuthorization}(s, f, t)$ true when the record is ACTIVE, its approval was created by a local commit, and that approval has not been invalidated. The registry must satisfy

$$\text{Exported}(s, f, t) \Rightarrow \text{CurrentLocalAuthorization}(s, f, t). \quad (2)$$

The finite model checks this property together with I1–I3.

The testbed checks rule creation and removal after gateway policy application, not instantaneous synchronization. An unreachable gateway may retain an older rule after registry invalidation. Conversely, an admission error can add an unsuitable review candidate without authorizing any rule.

TABLE II

LIFECYCLE TRANSITIONS. A SECOND DISPUTE MUST COME FROM A SITE DISTINCT FROM THE OPENER. UNDEFINED TRANSITIONS LEAVE THE RECORD UNCHANGED OR ARE REJECTED.

Current state	Event	Precondition	Next state	Token valid?	Exportable?
Absent	query/stage	admitted; no open dispute	MONITORONLY	no	no
MONITORONLY	local commit	local operator; no dispute	Active	yes, new	yes
MONITORONLY/Active	first dispute	valid dispute	Disputed	no	no
Disputed	second dispute	distinct reporting site	Revoked (Dispute)	no	no
Disputed/Revoked (Dispute)	global restore	authorized restore	MONITORONLY	no	no
Active/MONITORONLY	local revoke	local operator	Revoked (Local)	no	no
Revoked (Local)	local restore	no open dispute	MONITORONLY	no	no
Revoked (Local)	global restore	—	Revoked (Local)	no	no
Absent	dispute	—	Absent	no	no

TABLE III

ADMISSION NOTATION AND DEFAULTS. SEC. VI-E VARIES m , θ , AND α ; SEC. VI-E VARIES THE REALIZED f_s .

Symbol	Meaning	Value
d, e	device type; endpoint (direction, protocol, peer, port)	—
$A(d, e)$	endpoint-class eligibility (the class gate)	—
ES_d	sites with at least one observation of device type d	—
$S_{d,e}$	subset of ES_d that reports endpoint (d, e)	—
C_s	cross-site breadth, $ S_{d,e} / ES_d $	—
C_t	temporal-persistence confidence (Eq. 3)	—
$D_{d,e}, D_d$	UTC dates observing (d, e) ; dates observing any endpoint of d	—
$n_{d,e}, n_d$	pooled observation counts for (d, e) ; for all of d	—
$score(d, e)$	admission score, $\alpha C_s + \beta C_t$ (Eq. 4)	—
C_s^{trust}	trust-weighted breadth (Eq. 7)	—
w_i, b_i	site i 's trust weight; distinct fact breadth; reference	—
$breadth$	breadth	—
m	minimum reporting sites (quorum)	2
θ	admission threshold	0.65
α, β	breadth / temporal weight, $\alpha + \beta = 1$	0.6, 0.4
f_s	assumed adversarial breadth share	0.30

C. Candidate Admission

Admission controls proposal volume, not authorization. A fact reaches review only if it passes endpoint-class eligibility, reporter quorum, score, and dispute checks (Eq. 5); Table III gives the operating values.

Eligibility. After address filtering, $A(d, e) = 1$ for DNS, NTP, update, or vendor-cloud endpoints: DNS is `dns` or port 53, NTP is `ntp` or port 123, update names contain `update/upgrade/firmware/ota/fw./-fw/swupdate`, and vendor-cloud is any remaining FQDN; private, reserved, and link-local IP literals fail. We call this the *class gate*: a resolvability/control-plane filter, not an intent classifier, so a resolved attacker domain still clears it (Sec. VI-E).

Breadth is the fraction of sites observing device type d that report this endpoint: $C_s = |S_{d,e}|/|ES_d|$, where ES_d contains every site with at least one observation of d and $S_{d,e}$ those reporting (d, e) specifically (a site need not report this endpoint to enter the denominator) — a site-population definition distinct from the endpoint-class gate $A(d, e)$. Let $D_{d,e}$ be the union of UTC calendar dates of observations of (d, e) across sites, D_d the corresponding union for all observations of d , and $n_{d,e}, n_d$ their pooled observation counts. Temporal confidence, combining day coverage and frequency, is

$$C_t = 0.7 \frac{|D_{d,e}|}{|D_d|} + 0.3 \frac{n_{d,e}}{n_d} \in [0, 1]. \quad (3)$$

Admission score. Nonnegative weights α and β determine

the contributions of breadth and persistence, respectively. The score is

$$score(d, e) = \alpha C_s(d, e) + \beta C_t(d, e), \quad \alpha + \beta = 1. \quad (4)$$

Combined rule. Let θ be the minimum score and $openDispute(d, e)$ indicate an unresolved dispute. We require at least two distinct reporting sites ($m = 2$, the quorum); a larger quorum requires more reports and can delay admission, since authenticated identities alone do not establish independent behavior. Automatic admission to review is

$$\begin{aligned} admit_{auto}(d, e) = & (A(d, e) = 1) \wedge (|S_{d,e}| \geq m) \\ & \wedge (score(d, e) \geq \theta) \\ & \wedge \neg openDispute(d, e). \end{aligned} \quad (5)$$

Registry queries block disputed/revoked facts; OPERATOR-COMMIT remains necessary for Active.

We select weights from an external adversarial-breadth bound and threshold, then measure utility: raw-breadth parameters are $(\alpha, \beta) = (0.6, 0.4)$, $\theta = 0.65$, and $m = 2$. Sec. VI-E reports the empirical cost.

Parameter selection. The weights are not tuned on the corpus. We fix them from the external breadth bound, so admission arithmetic decides α before any dataset is seen.

Criterion 1 (Admission design constraint). If malicious contributors hold at most breadth share f_s of the eligible population and an endpoint fact is reported only by them, then $C_s \leq f_s$ and $C_t \leq 1$, so

$$score(d, e) \leq \alpha f_s + \beta = 1 - \alpha(1 - f_s). \quad (6)$$

Requiring this upper bound to fall strictly below θ constrains the parameters to $\alpha > (1 - \theta)/(1 - f_s)$, equivalently $f_s < 1 - (1 - \theta)/\alpha$.

The constraint is what selects the operating point. At $\theta = 0.65$ and $f_s = 0.30$ it admits no $\alpha \leq 0.5$: a design weighting persistence at least as heavily as breadth could be carried past θ by fabrication volume alone. We take $\alpha = 0.6$, which bounds an adversary-only score at 0.58 and tolerates breadth shares below about 0.42; Sec. VI-E prices this choice against the corpus optimum. The constraint is an arithmetic property of Eq. 4, not a security theorem: it inherits whatever bound the deployment governs f_s by, applies to raw breadth C_s only, and says nothing about contributors who accumulate genuine breadth. The bounded-A2 sweep and the port-masquerading counterfactual therefore use raw C_s ; Sec. VI-F evaluates

the trust-weighted and clustered variants empirically, and the temporal split within β is heuristic.

Sybil-aware variants. Trust weighting replaces raw breadth with

$$C_s^{trust} = \frac{\sum_{i \in S_{d,e}} w_i}{\sum_{i \in ES_d} w_i}, \quad w_i = \min(1, b_i/b_{ref}), \quad (7)$$

where $b_i = |\{(d, e) : i \text{ contributed } (d, e)\}|$ is site i 's distinct fact breadth across device types and b_{ref} is the median of these breadths in a frozen clean snapshot built before injection. b_i is recomputed on the population currently being scored, so every site—including a newly appearing identity—is weighted by its own present breadth, and padding raises b_i directly; only b_{ref} is frozen. This differs from the Reputation-Weighted Voting (RWV) reference point (Sec. V), which instead fixes weights once on the pre-attack population, giving an absent identity a flat probation weight regardless of later behavior.

Clustering groups sites with similar endpoint sets: for each device type, sites are graph vertices, an edge joins sets with Jaccard similarity (intersection over union) at least 0.8, and each connected component counts as one source. Writing $c(i)$ for site i 's component, clustered breadth is $|\{c(i) : i \in S_{d,e}\}|/|\{c(i) : i \in ES_d\}|$.

The registry and independent-deployment experiments use raw breadth. The UNSW retention funnel uses trust weighting; the identity-inflation experiment compares raw, weighted, and clustered variants. Weighting and clustering do not inherit Criterion 1's guarantee and depend on a clean reference or meaningful endpoint diversity.

Limitations. Days are unioned while counts are pooled, so busy sites affect frequency. Fleet changes can also rescore unrelated facts (Sec. VI-F).

V. IMPLEMENTATION AND METHOD

The conceptual baseline is pooled union plus local approval, without the lifecycle semantics of Sec. II.

The single-node Python registry (FastAPI, SQLAlchemy 2, SQLite) separates evidence/admission from local authority, flags, and history. Transactions atomically fan out dispute/restore for one fact; conflicting writes retry up to ten times. The API recomputes admission from stored observations and exports currently authorized facts as MUD; gateway fetch/reload remain separate. Distribution requires coordination of these transitions (Sec. VI-G).

Datasets. We use UNSW-IoTraffic [4], Mon(IoT)r [26], and YourThings [27]; Sec. VI-D uses the latter as a third independent deployment. UNSW supplies 27 device types and 28 traffic-derived reference profiles; its one physical capture is shuffled round-robin into ten seeded pseudo-sites (seed 42 unless stated). Collapsing Mon(IoT)r VPN variants yields independent US and UK captures, with 3,484,201 of 4,166,133 records surviving address filtering. Adapters require the five endpoint fields: UNSW uses same-site Host/SNI evidence for 24-hour IP-to-name correlation, Mon(IoT)r uses cumulative DNS, and we retain device-initiated transport flows with a port and global peer or public name. The serializer emits RFC 8520's resolved-name TCP/UDP subset, not RFC 9761

TLS/DTLS extensions [30]; 0.9% of reference ACEs (0.6% macro) are unrepresentable. Adapters and manifests are in the artifact.

Reference points. *Local-only* uses receiver facts; *pooled union* stages every fact. Its approval variant leaves Active records unchanged when evidence changes; a simple revoke permits withdrawal but specifies neither dispute fan-out nor restoration. DIB defines these semantics; this lifecycle comparison is not separately benchmarked. The admission ablation starts with *quorum-only* (two reporters), then adds scoring and class eligibility. *Frequency filtering* requires $n_{d,e} \geq 2$; the *50% registry*, $|S_{d,e}|/|ES_d| \geq .5$; and *RWV*, weighted support > 0.65 . RWV freezes pre-attack weights and assigns new identities 0.1, scaling with raw Sybil count unlike DIB's dynamic weighting.

Ground truth and randomization. Predictions match device, direction, normalized protocol, peer, and port; port 0, unknown protocol, and CIDR ranges are handled as wild-cards or membership. Micro metrics pool true/false positives/negatives; macro metrics average over the 28 UNSW reference profiles. Independent-deployment precision/recall/F1 measure agreement with the receiving site's observed traffic, not a manufacturer policy. Aggregates use seeds 0–19; A1, Sybil, and drift use seed 42, and cross-lab, OpenWrt, and concurrency use seed 0.

Enforcement testbed. A privileged Docker container with the OpenWrt 23.05.5 root filesystem runs unmodified osMUD commit 852918e, restarted per policy change to materialize MUD ACLs as nftables rules. Each transition records ACEs, effective rules, registry/osMUD state, and a live TCP probe. Unsigned experimental exports require disabling signature validation; production requires signed MUD and PKI.

Captured and synthetic events. A1 replays 165 captured malicious observations forming 59 facts to k pseudo-sites. Other tests inject fabrications, resolved-name and port masquerading, Sybil identities (200–3,200; 20–400 days), and rollouts, with endpoint sets diversified by 0/10/25/50% of a baseline pool; artifact configurations give full sampling details.

Artifact availability. Configurations, input hashes, generated MUD, gateway states/probes, TLA+ specifications/logs, matched ablations, and corrected-registry regression evidence are provided to reviewers at submission under a permissive licence at ANONYMOUS-ARTIFACT-LINK-TBD, with a permanent DOI to be minted on acceptance.

VI. EVALUATION

We evaluate lifecycle safety (RQ1), proposal-volume/coverage trade-offs (RQ2), and adversarial admission (RQ3). RQ1 distinguishes finite-model verification from registry, gateway, and reconciliation tests. RQ2 separates UNSW reference-profile coverage from independent-deployment traffic agreement; candidate counts quantify proposal volume, and Sec. VI-D converts them into review cost per confirmed endpoint; operator time itself is not measured. Precision/recall/F1 do not establish benignity or functional necessity. RQ3 distinguishes the conditional analytical bound from empirical mitigation; it tests admission, not approval.

TABLE IV

FINITE LIFECYCLE/EXPORT CHECKS OVER 3,837,084 REACHABLE STATES, WITH AUTHORIZATION VALIDITY, REVOCATION PROVENANCE, AND EVERY ACTION EXERCISED, INCLUDING LOCAL-REVOKE/LOCAL-RESTORE. REMOVING OPERATOR-COMMIT LEAVES 1,749,604 REACHABLE STATES, NONE ACTIVE. GATEWAY STATE IS EXCLUDED.

Property	Result	Mutation	Counterexample
Fresh auth only local commit	holds	—	—
Authorization-token coherence	holds	restore recreates token	authorization without commit
Export requires fresh authorization	holds	—	—
I2 site confinement	holds	cross-site commit	remote commit alters s'
I2 local-revoke confinement	holds	local-revoke fans out	remote site's record changes
I3 dispute invalidates authorization	holds	—	—
I3 global restore preserves local revoke	holds	restore ignores revocation origin	local veto erased
I3 local-restore conservative	holds	local-restore ignores open dispute	site escapes live dispute episode
Export requires Active	holds	disputed export	ACE emitted while Disputed
Dispute suspends everywhere; fact isolation (no other fact key changes)	holds	—	—
Active unreachable without commit	holds	—	—

A. RQ1: Authorization Safety (G1, G4)

Under Sec. III-A's identity assumptions, RQ1 checks authorization creation and withdrawal. Table I places local revoke before dispute because it is permitted only from MONITORONLY or Active. Restoration must preserve this veto while returning dispute-derived peer records to review.

Why the guards matter. Mutations expose three distinct failures: restoration regenerating tokens breaks authorization coherence; local restore during a dispute escapes suspension; resetting all revoked records erases local vetoes without necessarily creating permission. Preventing unauthorized activation alone does not preserve revocation semantics.

Finite-model verification. The TLA+ model explores arbitrary interleavings of lifecycle actions, multi-site disputes, and token invalidations across three sites and two endpoint facts. All 3,837,084 reachable states satisfy I1–I3 and export eligibility; every new authorization requires a local commit, including after restoration. Guard-removal mutations produce counterexamples (Table IV). Gateway enforcement and distributed linearizability are outside the model. An extension adds site reachability, a per-fact pending flag, and explicit reconciliation for the deployment in Sec. VI-G. Its dispute-suspension and conservative-restore properties apply to reachable, reconciled sites (718,571 states generated, 44,610 distinct, depth 18, no counterexample), not disconnected or unreconciled sites.

Registry regression. Replaying local revoke, two peer disputes, and global restore exposed a mismatch: the prototype reset both locally and globally revoked records to review. The correction checks revocation origin in the audit history. Regression tests cover one- and two-dispute episodes and repeated restoration; a service trace confirms that the local

TABLE V

INDEPENDENT PROPERTIES OF 564 ACES IN 28 REFERENCE PROFILES, EACH RELATIVE TO THE FULL BASE; NOT SUCCESSIVE FILTERS.

Independent property	Micro	Macro
All reference ACES (base)	100.0%	100.0%
Under from-device-policy	89.2%	83.4%
Class eligible for staging	99.1%	99.4%

TABLE VI

CUMULATIVE COVERAGE OVER THE SAME 564 REFERENCE ACES (TEN PSEUDO-SITES, TRUST-WEIGHTED ADMISSION). ROWS ARE NESTED SUBSETS; PERCENTAGES USE THE FULL REFERENCE BASE.

Cumulative pipeline stage	Micro (cum.)	Macro (cum.)
All reference ACES (base)	100.0%	100.0%
Observed and address-filtered	9.8%	12.4%
Staged by DIB	6.4%	7.9%

veto survives while the peer record returns to review. This correction is validated at the registry, not by a new gateway run.

Gateway result. On OpenWrt, unmodified osMUD consumes regenerated ACLs and yields:

- MONITORONLY exports no ACE or firewall rule;
- a local commit exports the fact, permitting one tested FQDN on TCP/8080 and UDP/5353;
- the first dispute reduces the export to zero ACES, removes the effective nftables rules, and causes the probe to be refused;
- a second-site dispute records Revoked with no further data-plane change;
- restore returns the fact to MONITORONLY; a fresh local commit restores access; and
- LOCAL-REVOKE at the local gateway site (Site s) removes both effective nftables rules after policy application and rejects the probe; LOCAL-RESTORE returns the fact to MONITORONLY.

All 10 repeat runs completed. Seven reversal cycles affected only the named fact, and distinct-site attestations were idempotent. The local-revoke/local-restore extension collapsed the firewall to one reject-all rule and retained it through restoration. Driving the same gateway through the distributed deployment (Section VI-G) instead of the in-process registry reproduces the same live nftables outcome for every transition.

B. RQ2: How Much Observable Behavior Is Retained?

Let A be staged reference-matching behavior, O the address-filtered observable reference behavior, and R the complete reference. *Retention* is A/O ; *complete-profile recall* is A/R , over 564 ACES in 28 UNSW profiles (macro values count unobserved chromecast-ultra as zero). Table V reports independent properties; Table VI reports cumulative coverage.

After address filtering, the traces expose 55 of 564 reference ACES (macro recall 0.124). DIB stages 36 of 564 (macro recall 0.079), retaining 63.2% of the observable macro behavior, computed from unrounded macro values.

Across the regenerated 20-seed graph-free ablation, the full rule accepts 344.55 ± 5.03 facts with macro agreement F1

TABLE VII

TWO-LAB FULL-CAPTURE QUEUE: Q =QUORUM, S =SCORE, C =CLASS GATE. FILTERS SHARE POOLED TWO-SITE EVIDENCE; ONLY UNION BASELINES AND REDUCTIONS DEPEND ON RECEIVER DEVICE SCOPE.

Stage / site	Candidates	Union	Red. vs union
<i>Site-independent (pooled two-site evidence)</i>			
Full DIB (QSC)	462	—	—
DIB without class gate (QS)	697	—	—
Quorum only (Q)	840	—	—
<i>Site-specific union baseline</i>			
US	—	24,121	98.1%
UK	—	6,707	93.1%

0.104 ± 0.001 . Independent-deployment cold-start transfer is evaluated separately (Sec. VI-D).

Comparison with local-only monitoring. On pseudo-sites from one UNSW capture, local-only monitoring reaches macro F1 0.022 ± 0.005 after 30 days; DIB’s day-0 cross-site candidates reach 0.112 ± 0.002 without local history, about $5.1\times$ on the ratio of means. Adding 30 days of local observation raises DIB only to 0.114 ± 0.002 : cross-site seeding accounts for nearly all the gain in this partition, not evidence of cross-organization transfer.

Most coverage loss precedes admission: device-initiated capture makes 61 to-device ACEs unreachable, and address filtering reduces 93 observed ACEs to 55. Class eligibility and direction are independent properties, explaining their different shares (Table V).

C. RQ2: How Many Candidates Require Review?

The independent Mon(IoT)r US and UK deployments isolate each filter’s effect on proposal volume. Collapsing VPN variants leaves 26 shared device types with mean endpoint-fact overlap 0.25; three types share no facts. Both deployments contribute evidence to this full-capture comparison (Table VII), unlike the held-out-receiver test below.

Quorum reduces the queue to 840, scoring to 697, and the class gate to 462 (452 serializable): 45.0% below quorum-only and 33.7% below no class gate. Union-relative reductions are 98.1% (US) and 93.1% (UK). Across 32 daily windows, arrivals remain bursty (15.9 additions per site-day; peak 432); Active facts that later fail admission are flagged, not removed.

D. RQ2: Proposals for a New Receiving Site

To evaluate a new receiver, we exclude it from reporter sets, eligible populations, days, and observation counts. With only US and UK, holding one out leaves one source and cannot satisfy $m = 2$, so we add YourThings (YT) [27], an independent historical deployment comprising one day and 40 packet captures. A fixed six-entry label mapping aligns the six device types observed in all three deployments.

Matched comparison. Every filter uses the same source observations and device scope (Table VIII). Precision, recall, and F1 are macro per-device agreement with receiver-observed endpoints; coverage is the fraction of six types receiving any proposal. Scored rows use raw breadth with $\alpha = 0.6$, $\beta = 0.4$, and $\theta = 0.65$. Deleting all receiver observations leaves DIB candidate sets unchanged; full-DIB rows reproduce the earlier three-deployment results exactly.

TABLE VIII

MATCHED COLD-START ABLATION: EACH RECEIVER USES THE OTHER TWO DEPLOYMENTS AS SOURCES. Q = TWO-SITE QUORUM; S = RAW-BREADTH SCORE; C = ENDPOINT-CLASS GATE. N COUNTS CANDIDATES; COV. IS DEVICE COVERAGE. P/R/F1 MEASURE MACRO AGREEMENT WITH RECEIVER TRAFFIC.

Receiver	Filter	N	Cov.	P	R	F1
US	Union	1005	100%	.322	.358	.327
	Q	42	83.3%	.750	.079	.139
	QS	40	83.3%	.750	.076	.135
	DIB (QSC)	36	83.3%	.750	.065	.116
UK	Union	767	100%	.279	.449	.320
	Q	48	83.3%	.745	.078	.138
	QS	48	83.3%	.745	.078	.138
	DIB (QSC)	43	83.3%	.784	.064	.115
YT	Union	1387	100%	.059	.334	.095
	Q	177	100%	.173	.282	.208
	QS	146	100%	.257	.282	.268
	DIB (QSC)	107	100%	.286	.223	.247

TABLE IX

REVIEW COST OF THE SAME NESTED QUEUES (SIX ALIGNED DEVICE TYPES, MICRO-AGGREGATED). CONFIRMED COUNTS CANDIDATES AGREEING WITH A RECEIVER-OBSERVED ENDPOINT: AGREEMENT, NOT BENIGNITY. BUDGET YIELD FIXES THE NUMBER OF INSPECTED ENTRIES AT THAT RECEIVER’S FULL-DIB QUEUE SIZE AND REVIEWS THE UNRANKED UNION QUEUE IN ARBITRARY ORDER.

Receiver	Filter	N	Conf.	Rev./conf.	Yield @budget
US	Union	1005	184	5.46	6.6
	Q	42	41	1.02	35.1
	QS	40	39	1.03	35.1
	DIB (QSC)	36	35	1.03	35.0
UK	Union	767	178	4.31	10.0
	Q	48	41	1.17	36.7
	QS	48	41	1.17	36.7
	DIB (QSC)	43	37	1.16	37.0
YT	Union	1387	49	28.31	3.8
	Q	177	41	4.32	24.8
	QS	146	41	3.56	30.0
	DIB (QSC)	107	37	2.89	37.0

Trade-off and review cost. DIB reduces candidates by 96.4% (US), 94.4% (UK), and 92.3% (YT) relative to union. The four configurations are nested subsets of one queue, so they are operating points on a single review-cost curve (Table IX) rather than competing systems. Union attains higher macro F1 at US and UK, but only by presenting a queue 13–28 times larger: an operator inspects 5.5 (US), 4.3 (UK), and 28.3 (YT) union entries per endpoint the receiver actually observes, against 1.03, 1.16, and 2.89 under full DIB. Each additional confirmed endpoint that union recovers beyond DIB costs 6.5 (US), 5.1 (UK), and 106.7 (YT) further entries. Held at equal effort—a budget equal to the full-DIB queue—DIB confirms 35.0 versus 6.6 (US), 37.0 versus 10.0 (UK), and 37.0 versus 3.8 (YT) endpoints. The union figures assume arbitrary review order, because a pooled queue defines none; any ranking that would improve it is itself an admission filter, which is the mechanism under evaluation. Filtering therefore wins at every receiver once effort, rather than queue exhaustion, is the constraint. Within the filtered region the ordering is receiver-dependent: quorum already reaches 35.1 (US) and 36.7 (UK) at the same budget, and only YT separates the score and class stages (24.8, 30.0, 37.0). Quorum provides most of the reduction; the later stages pay for themselves at YT and are close to neutral at US and UK.

TABLE X

PORT-MASQUERADING COUNTERFACTUAL: LARGEST QUORUM-CLEARING SCORE BY MALICIOUS-SITE FRACTION f_s AND FABRICATION HORIZON (PORTS 53/123 ELIGIBLE; PORT 443 CONTROL INELIGIBLE; $\theta = 0.65$).

f_s	Horizon (days)	Score	Outcome
0.30	120	0.562	rejected (below θ)
0.50	30	0.663	staged (MONITORONLY only)

Capture asymmetry. Observation windows and endpoint-set sizes differ. Full-DIB bootstrap 95% F1 intervals are [0.033,0.198] (US), [0.044,0.186] (UK), and [0.116,0.384] (YT); a busiest-single-day test gives F1 0.241/0.213/0.258. These six-device results do not rank receiving environments systematically; the artifact provides per-device counts and window diagnostics.

E. RQ3: Admission Inside the Breadth Bound

We test captured A1 observations separately from fabrications governed by the conditional bound. We inject 59 A1 facts at $k = 1, \dots, 10$ pseudo-sites and test resolved-name and port-masquerading fabrications. Bounded A2 crosses 20 seeds and malicious-site fractions $\{.05, .1, .2, .3, .4, .5\}$, each realized by uniformly sampling the corresponding rounded number of pseudo-sites.

DIB stages none of the 59 captured facts, whereas pooled union and frequency filtering stage all of them; their peers are unresolved IP addresses and remain below θ even when eligibility is bypassed. The baseline comparison quantifies the corresponding benign-coverage cost on the same seeded pseudo-site setting, with one exception: a locally observed endpoint left uncovered by the imported policy.

The bounded-A2 sweep uses raw C_s , without trust weighting or clustering; its sampled malicious-site share directly instantiates f_s . Everything in this subsection is conditional on the deployment governing that share.

The port-masquerading counterfactual holds other inputs fixed: ports 53/123 are eligible; the otherwise identical port-443 control is not. Extending fabrication to 120 days exceeds the one-day bounded-A2 maxima; both tests agree at the one-day horizon (0.354). Table X reports the largest quorum-clearing scores. At $f_s = 0.30$, rejection throughout is consistent with the analytical upper bound 0.58. At $f_s = 0.50$, outside the assumed region, the fact stages as MONITORONLY: admission failure adds a false proposal but cannot itself authorize enforcement.

Admission-parameter sensitivity (G5). We sweep $\theta \in [0.50, 0.80]$ and $\alpha \in [0.4, 0.9]$ on Mon(IoT)r and YourThings [27]; the selected $\alpha = 0.6$ satisfies Criterion 1’s $\alpha > 0.5$ requirement at $f_s = 0.30$, $\theta = 0.65$, bounding an adversary-only score at 0.58. At this operating point, Mon(IoT)r F1 is 0.054, against a corpus-best 0.071 at $\theta = 0.50$ or $\alpha = 0.9$: choosing parameters from the external threat bound rather than the corpus-specific optimum costs 0.017 F1.¹

Quorum sensitivity. Using the licensed UNSW input, we reran the seed-42 pseudo-site sweep over feasible quorums

$m \in \{1, 2, 3, 5\}$ and site counts $N \in \{2, 3, 5, 10\}$ ($m = 4$ needs an undistributed trace). At $N = 10$, $m = 1, 2, 3, 5$ each stage 346 facts and retain 63.17% of the capture-observable macro ceiling, so this partition does not empirically distinguish the lower quorums — not evidence that their adversarial tolerance is equivalent: $m = 2$ remains the smallest point requiring two distinct reports, and a cold-start receiver logically needs m external reporting sites. These are pseudo-site sensitivity results, not a consortium-size measurement.

F. RQ3: Admission Outside the Breadth Bound

Two tests leave Criterion 1’s assumption behind: fabricated identities exceed the breadth share, and behavioral drift stays consistent with it while being adversarial. Neither is covered by the analytical constraint, and both fail in the same restricted way—a false review candidate, never an authorization.

Fabricated identities. We evaluate identity inflation. Raw counting stages the fabrication in 45/48 representative cells; trust weighting and clustering reject it, whereas RWV admits all 48. These are not guarantees: padding real endpoints defeats clustering at the extreme cell (score 0.905), and no tested Jaccard threshold in $[0.6, 0.95]$ withstands every padding level. The complete grid is in the artifact.

Legitimate and malicious behavioral change. A synthetic rollout over 27 device types sweeps adoption $p \in \{.2, .4, .5, .6, .8, 1\}$ and duration $D \in \{1, 7, 30, 120\}$ over a 120-day horizon, labeling the same injected endpoint alternately as legitimate change or compromise. Both labels produce identical scores: 69 of 162 device-type/adoption cases admit within the horizon (median 7 days). Existing Active facts remain authorized for export and receive only a review flag.

This result exposes the limit of telemetry-only admission: a rollout and a slow compromise with identical endpoints and cadence are indistinguishable. A review flag calls for operator or out-of-band investigation (Sec. VII).

G. Management-Path Feasibility and Reconciliation

We rerun the corrected registry on a 16-core x86_64 Linux host using Python 3.10.13. At 1, 10, 50, and 100 writers, each worker executes 20 mixed service operations after an equally sized discarded warm-up; results average three repetitions. Throughput at 100 writers is 317.5 ± 10.8 operations/s, with median latency 3.8 ± 0.2 ms; p99 latency grows from 5.3 ± 0.4 ms at one writer to 5895.5 ± 191.4 ms at 100. All 9,660 timed operations complete without unexpected errors. These short service-level runs characterize contention, not sustained HTTP throughput or distributed scalability.

Nine correctness scenarios run 200 trials each; a retry-contention scenario runs 25 trials with 25 writers. All 1,825 trials report zero violations of the tested idempotency, dispute-exactness, local-revoke-race, site-isolation, and audit-history checks. These schedules do not prove linearizability; manifests and per-scenario results are in the supplement.

Distributed deployment. An evidence service hosts shared Score state and dispute/restore transitions; ten independent site services host their own LocalDecision records

¹The complete grid in the released artifact confirms the coverage-filtering trade-off described here.

TABLE XI

DISCONNECTED-SITE RECONCILIATION TRIALS. THE COMPOUND OUTAGE HIDES AN ENTIRE DISPUTE/RESTORE EPISODE; RECONCILIATION MUST INVALIDATE THE STALE GRANT DESPITE MISSING ALL INTERMEDIATE STATES.

Missed event(s) while disconnected	Trials	Converges to	Time (s)
Dispute-open only	10	authoritative state	0.51 ± 0.03 (n=30)
Confirming dispute only	10	authoritative state	
Restore only	10	authoritative state	
Compound: dispute-open + confirming dispute + restore	10	MONITORONLY, no valid grant	0.50 ± 0.04

and enforce revocation provenance locally. Dispute-open, confirming-dispute, and restore events fan out synchronously with bounded retries (3 attempts, 1 s each). For an unreachable site, a pending-fanout record retains the latest target state. Reconnection applies that record through the same idempotent path, ordered by a monotonic per-fact sequence number. This is a lifecycle/reconciliation mechanism under partial connectivity, not a claim of full distributed consistency.

At 100 concurrent writers (5 repeated runs) the distributed deployment sustains 530.3 operations/s with p99 latency 454.8±9.1 ms and no unexpected errors across the 2,000 timed operations of that load point. Throughput rises from 112.6 operations/s at one writer to 547.9 at 50 and 530.3 at 100, so the ten site processes absorb an order-of-magnitude increase in offered load without collapse, and median latency grows approximately linearly (9.5/35.9/90.7/168.7 ms at 1/10/50/100 writers) rather than super-linearly. This is the management path under HTTP, including synchronous dispute and restore fan-out to ten sites. It is a single-host operating point on a 16-core machine, not a distributed-scalability limit; the single-node measurements above are in-process service calls under a different operation mix and are not comparable to it.

Missed-event reconciliation. We run 40 fault-injection trials across four outage scenarios (Table XI). Three withhold one event type each. The compound case disconnects an Active site before dispute-open, confirming dispute, and restore, withholding the entire episode. Reconciliation must invalidate its stale grant directly from the final MONITORONLY target, without relying on prior receipt of Disputed. Thus collapsing pending events must preserve authorization invalidation, not merely the final state label. All 40 trials converge to the correct authoritative state after reconnection, applying exactly one collapsed fan-out record regardless of missed-event count. A further 20 trials, not tabulated, resolve races between reconciliation and new fan-out events correctly using sequence numbers.

Process restart (~0.45 s) dominates reconciliation logic (<0.1 s). Distributed services use direct SQLite access and no audit-history table, whereas the single-node registry uses SQLAlchemy with audit history; the two are reported independently for that reason.

Architectural ablation. Two alternatives contextualize per-site HTTP processes. Ten SQLite files across threads in one Python process showed no measurable improvement (p99 78.1 ms vs. 83.7 ms unsharded at 100 workers), consistent with GIL-serialized bytecode. Processes sharing files through

SQLite ATTACH performed worse (p99 30.0 s vs. 78.7 ms unsharded, 10 workers across 16 processes; one diagnostic run), consistent with WAL shared-memory contention. A forced write interruption rolled back all attached files in that case; WAL does not generally guarantee cross-database atomicity during commit crashes. Independent per-site processes without shared files performed best among these three configurations.

VII. DISCUSSION

Independent authority over shared evidence. DIB makes approval validity and revocation origin explicit so shared emergency withdrawal cannot silently reuse approvals or erase local vetoes on restoration. Its management value is this lifecycle across administrative domains, not a judgment that approved traffic is appropriate. Review time, decision quality, and usability remain unmeasured.

Smaller queues, lower coverage. Full-DIB macro F1 of 0.115–0.247 accompanies smaller queues: 462 candidates versus union’s 24,121 in US full capture, and 36–107 for cold-start receivers versus, for example, YT’s 1,387 union candidates (Tables VII–VIII). The relevant question is not which queue scores higher when fully reviewed, but which one an operator can afford to review: pooled union costs 4.3–28.3 inspected entries per confirmed endpoint against DIB’s 1.03–2.89 (Table IX). Quorum supplies most of that gain, and the later filters pay only at YT. Where an operator can exhaust the queue and a missed endpoint is costlier than a longer queue, quorum-only or QS remains the right operating point. Admission choices do not replace lifecycle authorization checks.

Coverage and transfer. The 0.25 US/UK endpoint overlap is consistent with environmental variability [29]. UNSW pseudo-sites measure within-capture retention, not cross-organization transfer or independent-consortium quorum robustness (Sec. VI-E). The three-deployment transfer test remains limited to six aligned device types (Sec. VI-D).

Adversarial evidence. Identical traffic can represent either legitimate rollout or attack; neither a score nor a review flag resolves intent. Criterion 1 assumes an externally governed f_s , informed by membership vetting or dispute history, not estimated from traffic. The fabrication is rejected at $f_s = 0.30$ but stages without authorization at $f_s = 0.50$ (Table X). Weighting and clustering are empirical mitigations, not general Sybil resistance. Identity controls and local review remain necessary; restrictive disputes prevent escalation but permit availability attacks.

Deployment limits. An unreachable gateway may retain stale permissions throughout a partition. Production requires pending/applied/stale monitoring and a connectivity-loss policy; default-deny leases remain unevaluated. The extended model checks I3 among reachable, reconciled sites, not immediate withdrawal everywhere. Fan-out retries for at most 3 s before queuing; reconciliation takes 0.51 ± 0.03 s on one host without WAN latency (Sec. VI-G). The model has no clocks or retry timers and establishes no 0.51 s deadline (Sec. VI-A). Gateway tests cover reachable, containerized OpenWrt only. The evidence service remains a single point of failure; its recovery is unevaluated.

VIII. CONCLUSION

DIB manages local MUD policy lifecycles from shared IoT evidence. Admission creates proposals; local approval creates authority; disputes invalidate it; restoration requires renewed approval and preserves local revocations. A finite TLA+ model checks these properties across 3,837,084 reachable states. Registry and reconciliation tests exercise the management path, while OpenWrt/osMUD demonstrates firewall changes on a reachable gateway.

The matched cold-start experiment reduces proposals by 92.3–96.4% relative to union, with higher precision and lower recall. Quorum provides most of the reduction; additional filters impose receiver-dependent costs. UNSW retention is 63.2% of observable macro behavior, with 7.9% complete-profile recall. At a fixed review budget these smaller queues confirm $3.7\text{--}9.8\times$ more endpoints than pooled union; whether that is the right operating point still depends on local coverage requirements. Under the stated trust assumptions, DIB's life-cycle governs authorization and reversal without establishing benignity or replacing local review.

REFERENCES

- [1] M. Antonakakis *et al.*, "Understanding the Mirai Botnet," in *Proc. 26th USENIX Security Symp.*, 2017.
- [2] E. Lear, R. Droms, and D. Romascanu, "Manufacturer Usage Description Specification," RFC 8520, IETF, Mar. 2019.
- [3] A. Hamza, D. Ranathunga, H. Habibi Gharakheili, M. Roughan, and V. Sivaraman, "Clear as MUD: Generating, Validating and Applying IoT Behavioral Profiles," in *Proc. ACM SIGCOMM Workshop IoT S&P*, 2018.
- [4] A. Sivanathan *et al.*, "Classifying IoT Devices in Smart Environments Using Network Traffic Characteristics," *IEEE Trans. Mobile Comput.*, vol. 18, no. 8, pp. 1745–1759, 2019.
- [5] A. Hamza *et al.*, "Verifying and Monitoring IoTs Network Behavior Using MUD Profiles," *IEEE Trans. Dependable Secure Comput.*, vol. 19, no. 1, pp. 1–18, 2022.
- [6] A. Hamza, H. Habibi Gharakheili, T. A. Benson, and V. Sivaraman, "Detecting Volumetric Attacks on IoT Devices via SDN-Based Monitoring of MUD Activity," in *Proc. ACM SOSR*, 2019.
- [7] F. Corno and L. Mannella, "A Gateway-based MUD Architecture to Enhance Smart Home Security," in *Proc. SpliTech*, 2023, pp. 1–6.
- [8] osMUD Project, "osMUD: Open Source MUD Manager," <https://osmud.org>. (Accessed Jul. 24, 2026.)
- [9] J. L. Hernández-Ramos, S. N. Matheu, A. Feraudo, G. Baldini, J. Bernal Bernabe, P. Yadav, A. Skarmeta, and P. Bellavista, "Defining the Behavior of IoT Devices Through the MUD Standard: Review, Challenges, and Research Directions," *IEEE Access*, vol. 9, pp. 126265–126285, 2021.
- [10] S. N. Matheu, J. L. Hernández-Ramos, S. Pérez, and A. F. Skarmeta, "Extending MUD Profiles Through an Automated IoT Security Testing Methodology," *IEEE Access*, vol. 7, pp. 149444–149463, 2019.
- [11] T. D. Nguyen *et al.*, "DfIoT: A Federated Self-learning Anomaly Detection System for IoT," in *Proc. IEEE ICDCS*, 2019, pp. 756–767.
- [12] E. Vasilomanolakis, S. Karuppayah, M. Mühlhäuser, and M. Fischer, "Taxonomy and Survey of Collaborative Intrusion Detection," *ACM Comput. Surv.*, vol. 47, no. 4, Art. 55, 2015.
- [13] A. Feraudo, P. Yadav, V. Safronov, D. A. Popescu, R. Mörter, S. Wang, P. Bellavista, and J. Crowcroft, "CoLearn: Enabling Federated Learning in MUD-Compliant IoT Edge Networks," in *Proc. ACM EdgeSys*, 2020, pp. 25–30.
- [14] L. Morgese Zangrandi, T. van Ede, T. Booij, S. Sciancalepore, L. Allodi, and A. Continella, "Stepping out of the MUD: Contextual Threat Information for IoT Devices with Manufacturer-Provided Behavior Profiles," in *Proc. ACSAC*, 2022, pp. 467–480.
- [15] C. Wagner, A. Dulaunoy, G. Wagener, and A. Iklody, "MISP: The Design and Implementation of a Collaborative Threat Intelligence Sharing Platform," in *Proc. ACM WISCS*, 2016, pp. 49–56.
- [16] OASIS CTI TC, "STIX Version 2.1," OASIS Standard, Jun. 2021.
- [17] S. D. Kamvar, M. T. Schlosser, and H. Garcia-Molina, "The EigenTrust Algorithm for Reputation Management in P2P Networks," in *Proc. WWW*, 2003.
- [18] A. Jøsang, R. Ismail, and C. Boyd, "A Survey of Trust and Reputation Systems for Online Service Provision," *Decision Support Systems*, vol. 43, no. 2, pp. 618–644, 2007.
- [19] M. Sloman, "Policy Driven Management for Distributed Systems," *J. Netw. Syst. Manage.*, vol. 2, no. 4, pp. 333–360, 1994.
- [20] A. Clemm, L. Ciavaglia, L. Z. Granville, and J. Tantsura, "Intent-Based Networking: Concepts and Definitions," RFC 9315, IETF, Oct. 2022.
- [21] E. Al-Shaer and H. Hamed, "Modeling and Management of Firewall Policies," *IEEE Trans. Netw. Serv. Manage.*, vol. 1, no. 1, pp. 2–10, Apr. 2004, doi: 10.1109/TNSM.2004.4623689.
- [22] A. Chowdhary, A. Sabur, N. Vadnere, and D. Huang, "Intent-Driven Security Policy Management for Software-Defined Systems," *IEEE Trans. Netw. Serv. Manage.*, vol. 19, no. 4, pp. 5208–5223, 2022, doi: 10.1109/TNSM.2022.3183591.
- [23] A. dos Santos Pires, F. M. Matos, A. Santos, D. Pessoa, *et al.*, "PipeConf: An Integrated Architecture for the Automated Configuration of Network Assets," *IEEE Trans. Netw. Serv. Manage.*, vol. 19, no. 3, Sep. 2022, doi: 10.1109/TNSM.2022.3195382.
- [24] A. Vergütz, B. V. dos Santos, B. Kantarci, and M. Nogueira, "Data Instrumentation From IoT Network Traffic as Support for Security Management," *IEEE Trans. Netw. Serv. Manage.*, vol. 20, no. 2, pp. 1392–1404, Jun. 2023, doi: 10.1109/TNSM.2022.3233673.
- [25] C. K. Rath, A. K. Mandal, and A. Sarkar, "Blockchain-based Dynamic MUD Profiles for Tamper-proof IoT Access Control," *J. Inf. Secur. Appl.*, vol. 95, Art. 104273, 2025, doi: 10.1016/j.jisa.2025.104273.
- [26] J. Ren, D. J. Dubois, D. Choffnes, A. M. Mandalari, R. Kolcun, and H. Haddadi, "Information Exposure From Consumer IoT Devices: A Multidimensional, Network-Informed Measurement Approach," in *Proc. ACM IMC*, 2019, pp. 267–279, doi: 10.1145/3355369.3355577.
- [27] O. Alrawi, C. Lever, M. Antonakakis, and F. Monrose, "SoK: Security Evaluation of Home-Based IoT Deployments," in *Proc. IEEE Symp. Security and Privacy*, 2019.
- [28] D. Y. Huang, N. Aphorpe, F. Li, G. Acar, and N. Feamster, "IoT Inspector: Crowdsourcing Labeled Network Traffic from Smart Home Devices at Scale," *Proc. ACM Interact. Mob. Wearable Ubiquitous Technol.*, vol. 4, no. 2, Art. 46, 2020.
- [29] W. He, K. Bryson, R. Calderon, V. Prakash, N. Feamster, D. Y. Huang, and B. Ur, "Can Allowlists Capture the Variability of Home IoT Device Network Behavior?" in *Proc. IEEE EuroS&P*, 2024, pp. 114–138, doi: 10.1109/EuroSP60621.2024.00015.
- [30] T. Reddy, K. D. Wing, and B. Anderson, "Manufacturer Usage Description (MUD) for TLS and DTLS Profiles for IoT Devices," RFC 9761, IETF, Apr. 2025.
- [31] A. Lotto, S. Sciancalepore, A. Brighente, and M. Conti, "FIDEM: A Standard-Compliant Framework for Secure Binding of MUD Profiles to IoT Devices," *arXiv preprint arXiv:2605.29654*, May 2026.
- [32] A. Zhang, X. Lee, Z. Zhuang, J. Wei, Y. Fu, and B. Peng, "POLARIS: Cross-Domain Access Control via Verifiable Identity and Policy-Based Authorization," in *Proc. IEEE 24th Int. Conf. Trust, Security and Privacy in Computing and Communications (TrustCom)*, 2025, pp. 1489–1498.
- [33] Y. Liu *et al.*, "Secure and Scalable Cross-Domain Data Sharing in Zero-Trust Cloud-Edge-End Environment Based on Sharding Blockchain," *IEEE Trans. Dependable Secure Comput.*, vol. 21, no. 4, pp. 2603–2618, 2024, doi: 10.1109/TDSC.2023.3313799.
- [34] J. Sun *et al.*, "Sanitizable Cross-Domain Access Control With Policy-Driven Dynamic Authorization," *IEEE Trans. Dependable Secure Comput.*, vol. 22, no. 4, pp. 4126–4142, 2025, doi: 10.1109/TDSC.2025.3541819.

Author One received the Ph.D. degree in [field] from [university] in [year]. [He/She/They] is currently [position] at [institution]. Research interests include [topic one], [topic two], and [topic three].

Author Two received the Ph.D. degree in [field] from [university] in [year]. [He/She/They] is currently [position] at [institution]. Research interests include [topic one], [topic two], and [topic three].



Author Three received the Ph.D. degree in [field] from [university] in [year]. [He/She/They] is currently [position] at [institution]. Research interests include [topic one], [topic two], and [topic three].



Author Four received the Ph.D. degree in [field] from [university] in [year]. [He/She/They] is currently [position] at [institution]. Research interests include [topic one], [topic two], and [topic three].



Author Five received the Ph.D. degree in [field] from [university] in [year]. [He/She/They] is currently [position] at [institution]. Research interests include [topic one], [topic two], and [topic three].



Author Six received the Ph.D. degree in [field] from [university] in [year]. [He/She/They] is currently [position] at [institution]. Research interests include [topic one], [topic two], and [topic three].



Author Seven received the Ph.D. degree in [field] from [university] in [year]. [He/She/They] is currently [position] at [institution]. Research interests include [topic one], [topic two], and [topic three].